Fortifying Mobile Money: A Case for Darktrace at Safaricom / M-Pesa

ISM 6331 — Information Systems Security | Product/Service Demo Synopsis

Brenda Kinoti

1. Business Case and Need

Safaricom's M-Pesa platform serves over 51 million users across seven countries and processes KES 36.4 trillion annually, roughly 43% of Kenya's GDP (Safaricom, 2023). M-Pesa runs entirely on USSD: users dial *144#, navigate a text menu, and authorize transactions with a PIN. No internet, no smartphone, no bank account required. Every transaction is confirmed through an SMS one-time password (OTP) sent to the registered phone number. Whoever controls that number controls the money. Safaricom agents can transfer any number to a new SIM on request. The Communications Authority of Kenya (2023) documents KES 2.1 billion in mobile money fraud losses in a single year, with SIM swap fraud as the leading vector. A Business Impact Analysis (BIA) (Chapple et al., 2024) defines this as an assessment of financial and reputational disruption confirms the urgency

Ch. 1 — CISSP Guide — Authentication & Nonrepudiation

Authentication is proving identity, not just claiming it. Nonrepudiation ensures a subject cannot deny performing an action. A SIM swap bypasses authentication: the fraudster provides the victim's name and ID (identification) but never proves they are that person. Darktrace's behavioral evidence reports provide nonrepudiation data, enabling Safaricom to trace drained funds and support victim recovery claims.

2. The Threat: SIM Swap Fraud

1	Attacker collects PII — name, ID number, phone — via phishing or data breaches.
2	Attacker calls Safaricom support, impersonates the victim using social engineering principles (urgency, pretexting), and requests a SIM replacement.
3	Agent complies. Victim's phone loses signal. Attacker's SIM now owns the number.
4	All OTPs route to attacker. They log into M-Pesa and authorize transfers.
5	Account drained in 3–5 minutes (Makori & Otieno, 2022).

Figure 1. SIM Swap Fraud — Five-Step Attack Flow

Ch. 2 — CISSP Guide — Social Engineering Principles & Security Awareness Training

Social engineering manipulates people using urgency, trust, and authority to bypass security protocols. Security awareness training teaches employees to recognize and resist these tactics. Step 2 of the attack is pure pretexting. (Chapple et al., 2024) explains that fraudsters fabricate a scenario to establish false legitimacy with a helpful agent. Until agents are trained specifically on recognizing pretexting and refusing SIM swaps without out-of-band identity verification, no technical control fully compensates.

Ch. 4 — CISSP Guide — PII & Identity Theft / Assumption Deterrence

PII is data that identifies a specific individual. Identity theft occurs when an attacker assumes another's digital identity for unauthorized financial gain. Step 1 weaponizes PII — name, ID, date of birth. Kenya's Data Protection Act 2019 places an obligation on Safaricom to prevent PII from becoming a fraud enabler (Chapple et al., 2024). Once the swap completes, the fraudster has fully assumed the victim's digital identity.

Ch. 9 — CISSP Guide — SIM Swapping & Device Lockout

SIM swapping redirects a victim's number to an attacker-controlled SIM. Device lockout places an account in a restricted state following suspicious activity. (Chapple et al., 2024) Ch. 9 explicitly identifies SIM swapping as a carrier-level countermeasure failure. The recommended control: when a SIM disconnects, the M-Pesa account should automatically lock until the genuine holder verifies identity in person,eliminating the 3–5-minute drain window.

3. The Solution: Darktrace

Darktrace is an AI-powered security platform that learns what normal behavior looks like for every account: device, location, transaction times, amounts, recipients, then autonomously flags and responds to deviations. Darktrace's (2023) Enterprise Immune System white paper describes this as unsupervised machine learning: the AI determines 'normal' independently, with no rules or signature databases. When a SIM swap occurs, the pattern breaks immediately: wrong device, wrong location, abnormal transaction velocity. Darktrace detects this in seconds. Its Antigena module then acts: transactions suspended, re-authentication forced, security team alerted. Response time: two to four seconds. Abdallah et al. (2021) found that AI anomaly detection reduces mean time to detection for financial fraud by up to 87% versus signature-based systems. The attack window is 3–5 minutes. Darktrace responds in 2–4 seconds.

Ch. 8 — CISSP Guide — Zero Trust & Secure Defaults

Zero Trust assumes no request is trustworthy by default — every access must be verified. Secure defaults configure systems to their most restrictive state unless explicitly relaxed. Darktrace operationalizes Zero Trust behaviorally: every M-Pesa action is evaluated against the account's specific baseline, not just whether it arrived through the right channel. (Chapple et al., 2024) also recommends secure defaults: locking a line for 24 hours after a SIM swap by default, creating a layered barrier no fraudster can clear within the current attack window.

Ch. 17 — CISSP Guide — Detection & Mitigation (Containment)

Detection identifies that an incident has occurred. Containment limits further damage once a breach is suspected. (Chapple et al., 2024) notes that end users often detect incidents first here, when their phone goes offline. Safaricom needs a rapid-response channel treating 'lost signal' reports as security incidents. Darktrace provides automated detection and containment before the user even calls in: transactions stop, the account isolates, and the window closes.

4. Product Comparison

Criteria	Darktrace	IBM QRadar	Vectra AI
Detection method	Unsupervised ML — no rules	Rule-based SIEM	Supervised NDR
Novel attack detection	YES — behavior-based	NO — signatures only	PARTIAL
Autonomous response	YES — 2–4 sec (Antigena)	NO — manual only	YES — less mature
Africa market presence	Strong — Kenya & SA	Moderate	Minimal
Annual cost (est.)	$150K–$400K	$100K–$350K	$120K–$500K

Figure 2. Competitor Comparison — Darktrace vs. IBM QRadar vs. Vectra AI

5. Implementation, Risk Evaluation, and Management

Phase	Timeline	Key Activities
Phase 1	Months 1–3	Deploy sensors. AI builds behavioral baselines in passive mode only — zero disruption to live operations.
Phase 2	Months 4–6	Antigena activates in confirm-before-act mode. Run SIM swap simulations (misuse case testing). Mandatory agent security awareness training.
Phase 3	Months 7–12	Full coverage across all 7 countries. Antigena fully autonomous. Integrate crisis management and IR protocols.

Figure 3. 12-Month Phased Implementation Plan

Ch. 15 — CISSP Guide — Misuse Case Testing & Social Engineering Pen Testing

Misuse case testing scripts known attack scenarios to find gaps. Social engineering pen testing uses controlled impersonation calls to validate agent training. Phase 2 includes both. Scripting the 5-step attack against Safaricom's actual agent workflow identifies where impersonation goes undetected (Chapple et al., 2024) Ch. 15. White-hat callers attempting fraudulent SIM swaps confirm whether training is working before Antigena goes fully live.

Ch. 2 & 3 — CISSP Guide — Separation of Duties & External Dependencies

Separation of duties divides critical tasks so no single person can compromise a system. External dependencies require that third-party vendor security match the organization's own standards. The team configuring Darktrace's thresholds must be separate from the team authorizing responses — no single insider subverts both (Chapple et al., 2024) Ch. 2. If Safaricom outsources call center operations, those vendors must follow identical SIM swap verification SLAs and be included in Phase 2 penetration testing scope (Chapple et al., 2024) Ch. 3.

Ch. 18 — CISSP Guide — RPO & Emergency Communications

The RPO defines how far back transactions can be reversed after a disruption. Emergency communications reach affected parties when primary channels are unavailable. Safaricom must be able to identify and reverse fraudulent M-Pesa transfers within a defined RPO window once a swap is confirmed (Chapple et al., 2024) Because the victim's phone line is offline, out-of-band contact channels — registered email, secondary number — must be operational before go-live.

6. Recommendation

Implement Darktrace at Safaricom / M-Pesa.

Speed: 2–4 second response versus a 3–5 minute attack window — no human team or rule-based system closes that gap.

Intelligence: Unsupervised AI detects social-engineering-based, zero-day attacks without pre-programmed signatures (Abdallah et al., 2021).

Reach: Regional integrators in Kenya and South Africa support deployment across all 7 countries.

ROI: $150K–$400K annually against KES 2.1 billion in documented losses (Communications Authority of Kenya, 2023). The qualitative cost — loss of goodwill and customer trust across 51 million users — makes inaction an even greater risk (Chapple et al., 2024)

7. Source Evaluation

Source	Accuracy	Bias	Credibility	Timeliness
Abdallah et al. (2021) Peer-reviewed journal	Strong empirical methodology	Academic — minimal bias	Scopus-indexed	2021 — relevant
Makori & Otieno (2022) Peer-reviewed journal	Region-specific fraud data	Academic — no commercial interest	Double-blind reviewed	2022 — current
Gartner (2022) Industry report	Vendor comparison analysis	Vendor-funded — triangulated	Globally recognized	2022 — current
CA Kenya (2023) Government report	Official national statistics	No commercial bias	Primary regulatory body	2023 — most current
Darktrace (2023) Vendor documentation	Product specs, detailed	Promotional — specs only	Verified independently	2023 — current
Safaricom (2023) Annual report	Audited financial data	Self-reported, cross-referenced	Listed co., regulated	2023 — current
Ciampa (2022) InfoSec textbook	Peer-reviewed academic text	Educational — no bias	Industry-standard reference	2022 — current edition

Figure 4. Source Evaluation — Accuracy, Bias, Credibility, Timeliness

References

Abdallah, A., Maarof, M. A., & Zainal, A. (2021). Fraud detection system: A survey. Journal of Network and Computer Applications, 68, 90–113. https://doi.org/10.1016/j.jnca.2016.04.007

Ciampa, M. (2022). CompTIA Security+ guide to network security fundamentals (7th ed.). Cengage Learning.

Communications Authority of Kenya. (2023). Cybersecurity report for the financial year 2022/2023. https://www.ca.go.ke

Darktrace. (2023). Enterprise immune system: AI threat detection for financial services [White paper]. https://www.darktrace.com

Gartner. (2022). Market guide for network detection and response. Gartner Research.

Makori, E. O., & Otieno, J. A. (2022). Mobile money fraud in sub-Saharan Africa: A systematic review. African Journal of Information Systems, 14(2), 45–68.

Safaricom. (2023). Safaricom annual report and financial statements 2022–2023. https://www.safaricom.co.ke

Chapple, M., Stewart, J. M., & Gibson, D. (2024). *ISC2 CISSP certified information systems security professional official study guide* (10th ed.). Wiley.